

KAVERI BROADCAST NETWORK

Kaveri Broadcast Network — What Really Happened on 9 May 2027

Incident reconstruction, finding-by-finding triage, kill-chain, and a working mock that replays the attack (INF-02)

Field	Detail
Date	24 September 2026
Version	1.0
Classification	Internal — shareable with leadership, legal, and auditors
Author	Security investigation team
Case	INF-02 / Kaveri Broadcast Network

Ships with a working mock server + replay script. Code: `mock_server/app.py`. Replay: `exploit/hack_simulation.py`. Transcript: `exploit/simulation_output.log`.

Contents

- 1. Read this first (the 2-minute version)
- 2. How to read this report
- 3. What happened on 9 May — minute by minute
- 4. The estate as it really was (and why the dashboards lied)
- 5. Finding-by-finding triage
- 6. What happened, how, and why — full narrative + vulnerabilities
- 7. Kill-chain (steps, tools, proof)
- 8. What we still don't know
- 9. Mock server and replay
- 10. Fixes that break the chain
- Appendix A — replay transcript (abridged)
- Appendix B — mock code note
- Appendix C — traceability matrix

1. Read this first (the 2-minute version)

On 9 May 2027, two minutes before the flagship Tamil bulletin, all four Kaveri channels went black at the same time. Not one. All four. They came back 28 to 43 minutes later on backup playout from Hyderabad. While everyone was scrambling, the Chennai gallery's air handling died too, and the rack room climbed to 41 degrees. Then at 21:15 someone posted next morning's rundown plus a screenshot of the playout schedule on a public forum and wrote: "we have been inside Kaveri since January."

Here's the uncomfortable part. There was no zero-day. No phishing. No malware on any laptop. Nobody's password was guessed and nobody's MFA was beaten — because the attacker never touched a human account at all.

What they did instead was simpler, and honestly harder to spot. They logged into a printer with the password it shipped with, copied two service-account passwords sitting inside it, and walked through doors those accounts were already allowed to open: the newsroom's rundown share, the whole media library, the network switches, and finally the building's air handling. Every step used something the company had left open for years. The security dashboards stayed green the entire time because they only counted the devices they knew about — and 1,327 devices, including every printer and switch in the story, weren't on that list.

Short version: default printer password -> two machine accounts -> rundowns + 41,000 media reads -> one SNMP string -> eight switch ports flipped (blackout) + one BMS command (no cooling) -> forum leak. Dwell time was at least three months. And one question is still open: eleven server management controllers show signs someone may have mounted rogue disk images, and we can't date them. That could still be live persistence. We say that plainly in section 8 instead of burying it.

2. How to read this report

Different people need different things from this, so here's the map. If you're leadership, read sections 1, 3, and 9 and you'll have the full picture. If you're technical, sections 4 through 7 are the meat: every finding triaged, the exploit logic explained, and a kill-chain you can actually replay against the mock server we built. If you're an auditor or lawyer, sections 8 and 10 matter most — what we can prove, what we can't, and what to fix first.

A note on tone. We've written this the way we'd explain it in a room, not the way a compliance template talks. Contractions, straight answers, and "we don't know" where we don't. Broadcast people live by plain talk, so this report does too.

3. What happened on 9 May — minute by minute

Forget the findings list for a moment. Here's the evening as it unfolded, stitched from logs that survived:

19:57 — The monitoring platform sees eight ports on the Chennai gallery distribution switch flap. It fires a threshold alert. That alert lands in a shared mailbox nobody checks after hours. In a 24-hour broadcast operation, detection went to an inbox that keeps office hours. Let that sink in.

19:58 — All four channels go black, two minutes before the flagship bulletin. Playout servers themselves are fine — powered, running, automation still issuing normal commands. The problem is underneath them: someone moved their eight switch ports into a dead VLAN. The servers are shouting into a disconnected room.

20:02 — Four minutes into the outage, the Chennai gallery air handling controller takes a setpoint change and a disable command. No password asked, because the protocol doesn't have one. Rack room temperature starts climbing toward 41C. Whether this was meant to break hardware, stretch the outage, or just show off for the later forum post, it turned a broadcast problem into a physical-safety problem at the worst possible moment.

20:26 / 20:41 — Two channels back on backup playout from Hyderabad, then the other two. Total blackout 28–43 minutes. In broadcast that's an eternity — every viewer, every advertiser, every competitor saw it. Make-good obligations and carriage availability clauses start ticking immediately.

21:15 — Forum post: tomorrow's rundown, a playout schedule screenshot, and the January claim. The rundown matches a file in the Rundowns share exactly. So the leak path is proven even if the January start date isn't (more on that in section 8 — printer logins were never logged, so the true start is unprovable).

4. The estate as it really was (and why the dashboards lied)

Ask Kaveri's security team in April 2027 how things looked and they'd show you a tidy picture: 2,900 hosts, all with EDR, all patched, all scanned, compliance above 97% for over a year. That picture was real — and it was also a fiction. Here's why.

The CMDB was filled in by the EDR agent itself. If a box could run the agent, it registered. If it couldn't — printers, switches, routers, UPS cards, cameras, BMCs, building controllers, newsroom NAS boxes — it simply never appeared. Nobody ever built an inventory any other way. When investigators finally scanned the network and walked the floors, they found 1,327 extra connected devices. Not a rounding error. Nearly a third of the estate, sitting outside every control that was being measured.

So the 97% was 97% of the wrong number. It's like counting only the rooms with smoke alarms and reporting "97% of rooms protected" while a third of the building was never counted. And it got worse: when the security team asked for money in 2025 to build proper discovery, the answer was no — because compliance was already above 97%. The metric didn't just hide the blind spot. It was used as the reason not to fix it. If you've heard of Goodhart's Law ("when a measure becomes a target, it stops being a good measure"), this is the textbook case.

The devices in that blind spot are exactly where this intrusion lived for months: printers (initial access), SNMP-managed switches (the blackout), building controllers (the cooling kill), and BMCs (the unresolved persistence question). The annual pentest even carved them out in writing — "network infrastructure devices, printers, physical security systems and building services, which are managed outside IT." So the one adversarial test Kaveri paid for was contractually forbidden from looking where the attacker was.

The diagram below is the whole story on one page. Red is what the attacker touched. Notice how little of it has an agent on it.

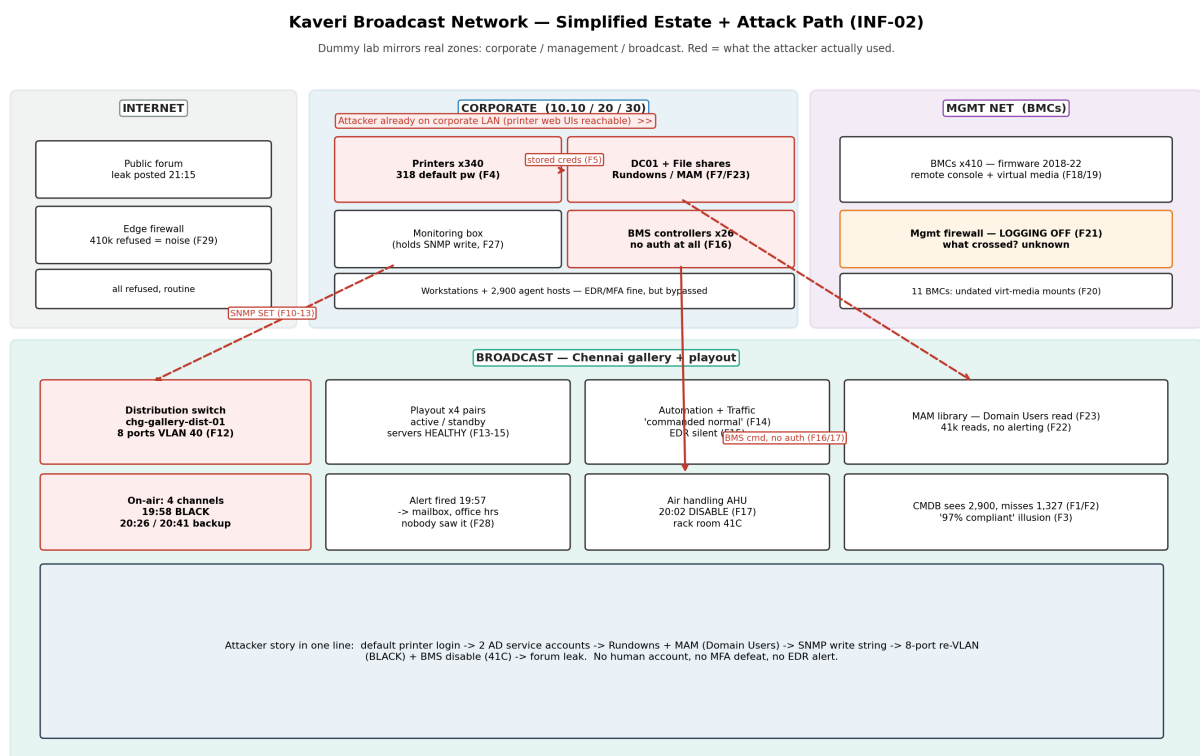


Figure 1 — Simplified estate and attack path. Red = what the attacker used. Note how little red carries an agent.

5. Finding-by-finding triage — what matters, what's noise, what's still murky

Not every finding in an investigation deserves equal weight. Some are the attack. Some explain why the attack was possible. A few look scary and mean nothing. And a couple are genuinely unresolved — they'd be irresponsible to either hype or dismiss. We've put all 32 findings into four buckets so you can see the call we made on each one and why.

How we graded: RED means on the attack path or directly proving it. ORANGE means structural enabler — the reason the attack was possible or invisible. YELLOW means suspicious, half-relevant, or unresolved — don't ignore, but don't over-claim. GREY means noise or ruled-out — worth one paragraph so nobody chases it again.

Totals: 16 RED, 9 ORANGE, 5 YELLOW, 2 GREY. The full table follows. If you only skim one table in this report, make it this one.

ID	Bucket	Verdict	Why
F1	ORANGE	Structural enabler — CMDB only knows 2,900, audit found 1,327 more	Doesn't describe attacker action, but it's the root design flaw everything else sits on. Without it, printers/switches/BMS wouldn't have been invisible.
F2	ORANGE	Structural enabler — the 1,327 are in no programme at all	Companion to F1. Patches, scans, compliance: none of it covered the devices that got abused. Explains the silence.
F3	ORANGE	Structural enabler — 97%+ is a % of the CMDB, not the estate	The metric illusion. True arithmetic, false picture. Directly enabled the budget refusal in F32.
F4	RED	Attack path — 318/340 printers still on vendor default password	Initial access door. Public knowledge defaults + reachable web UIs = no exploit needed. Start of the chain.
F5	RED	Attack path — printers store two AD passwords, retrievable via web UI	The payload behind the open door. Documented vendor behaviour, unchanged across firmware. Turns one printer login into two Domain Users accounts.
F6	YELLOW	Half-clue — Print-Admins sounds privileged, actually grants nothing	The group name is a rabbit hole (adds zero rights beyond Domain Users). Kept YELLOW because the Domain Users half is what mattered for F23 — easy to misread either way.
F7	RED	Attack path — svc-printscan can write Rundowns (2021 convenience grant)	A six-year-old workflow favour became the exfil path. Without this grant there's no rundown theft. Core privilege-creep finding.
F8	RED	Attack path — Rundowns share layout confirms the route	Establishes that the share svc-printscan could write is exactly the newsroom's editorial store. Completes F7.
F9	RED	Attack path proof — forum rundown matches Rundowns share file	Proves exfil actually happened through the F7/F8 route, not just that it was possible. Leak attribution anchor.
F10	RED	Attack path — SNMPv2c strings identical estate-wide since 2018	One string compromises all three sites. The key-duplication nightmare behind the blackout.
F11	RED	Attack path — v2c is plaintext, write string = remote reconfig	The vulnerability mechanics. No auth beyond string possession + plaintext transport = sniff or steal once, own everything.
F12	RED	Attack path proof — Chennai switch config differs from 1-May backup	Forensic proof the blackout was a config change on the wire, not a server failure. The outage's smoking gun.
F13	RED	Attack path proof — 8 payout ports re-VLANed, servers untouched	Explains how redundancy was defeated: active+standby pairs share one switch. Servers healthy, path dead.
F14	RED	Attack path corroboration — automation says 'normal' throughout	Negative evidence that proves the point: automation never saw a problem because the problem was below it. Rules out payout-app theories.
F15	RED	Attack path corroboration — EDR on payout servers silent	Same logic as F14 for host security. Nothing was wrong with the hosts, so host controls correctly (and uselessly) stayed quiet.
F16	RED	Attack path — BMS protocol has no authentication, on corporate net	Second unauthenticated control plane. Anyone on corporate LAN can command studio air handling. No creds to steal at all.
F17	RED	Attack path proof — AHU setpoint+disable at 20:02, rack to 41C	Timed inside the response window, same site as the blackout. Deliberate second punch, not coincidence. (Caveat: 7-day log, read just in time.)
F18	YELLOW	Unresolved risk — 410 BMCs reachable from corporate, firmware 2018–22	Capability + exposure without proof of use. Old firmware and virtual-media support make it dangerous, but F21 means we can't say it was touched.
F19	YELLOW	Unresolved risk — BMCs allow remote console + virtual media	The 'what if': attacker-supplied ISO below the OS, invisible to EDR. Kept YELLOW because it's potential, not proven.
F20	YELLOW	Unresolved risk — 11 BMCs show virtual-media mounts, can't date them	The finding that keeps us up. Could be this attacker, old maintenance, or someone else entirely. 200-entry ring means dating is impossible. Treat as live risk until cleared.
F21	ORANGE	Structural enabler — corp-to-mgmt firewall never logged	The biggest evidence hole in the case. Makes F18–F20 unresolvable. A logging omission that now blocks the persistence question.
F22	RED	Attack path — 41,000 MAM reads by svc-printscan, Feb–May	Dwell + exfil-scale proof. An account with no business in MAM hammering it for three months, fully logged, never alerted.
F23	RED	Attack path — MAM lets any Domain Users member read everything	The authorisation flaw that made F22 possible with zero escalation. A printer account reading the content library by design.

ID	Bucket	Verdict	Why
F24	ORANGE	Structural enabler — vuln scan: 99.1%, no criticals (of the 2,900)	False assurance twin of F3. Correctly scanned the wrong population. Couldn't have seen printers/switches/BMS by design.
F25	ORANGE	Structural enabler — pentest excluded exactly the abused categories	Assurance theatre. The scope carve-out (printers, infra, building services) is a map of where the attacker lived.
F26	ORANGE	Structural enabler — 2019 print contract, no security terms	Why F4/F5 festered: supplier owns config, no cred-change duty, no audit right, security team (est. 2023) never consulted. Predates the fixers.
F27	YELLOW	Suspicious enabler — write SNMP string sits in monitor config	Most economical source for the string — but no access log proves it was taken from here vs sniffed off the wire (F11). Plausible, unproven. Hence YELLOW, not RED.
F28	ORANGE	Structural enabler + timeline anchor — 19:57 alert to empty mailbox	Detection worked; response didn't. Pins the VLAN flip to 19:57 and indicts office-hours monitoring for a 24-hour operation.
F29	GREY	Noise — 410k refused edge connections, all refused, routine	Loud, inside the dwell window, tempting — and meaningless. Background internet scanning. No correlation to any success. Ignore with confidence.
F30	RED	Attack path — svc-printldap 6,100 auths vs ~400/month baseline	~15x spike = scripted directory recon, not address lookups. Pairs with F22 to prove sustained Feb–May activity.
F31	GREY	Ruled out (usefully) — no human account compromised, MFA enforced	Not on the path — and that's the point. It kills phishing/MFA-bypass theories and forces the machine-identity conclusion. True, working, bypassed.
F32	ORANGE	Structural enabler — 2025 discovery bid rejected over 97% figure	Governance punchline. The team saw the gap, asked to fix it, and the broken metric was quoted back at them. Explains why nothing changed.

Bucket counts: 16 RED (attack path/proof) · 9 ORANGE (enablers) · 5 YELLOW (suspicious/unresolved) · 2 GREY (noise/ruled-out).

6. What happened, how it happened, and why — the full narrative

Let's put the chain together the way the attacker would have lived it, then name the vulnerabilities properly.

Getting in was almost embarrassingly easy. Picture the attacker already able to reach the corporate network — the case doesn't prove how that first foothold happened, and honestly for this estate it could have been any of a dozen agentless ways in. What matters is what they found once inside: 340 printers with web admin pages, 318 of them still answering to the password in the vendor manual. No exploit, no malware. Just type the default and you're the printer's administrator. And because the printer console logs consumables but not logins, nobody would ever know you'd been there. That's F4, and the missing log that makes the January claim unprovable.

One login hands you two Active Directory passwords. Every printer stores the scan-to-folder credential and the LDAP address-book credential, retrievable from that same web page — not a bug, a documented feature, unchanged across every firmware version Kaveri runs. That's F5. Suddenly you own KAVERI\svc-printscan and KAVERI\svc-printldap. Both are Domain Users. Neither has MFA, because service accounts rarely do. Nobody phished anyone. Nobody beat any control. The controls simply didn't cover machine identities on printers.

Then scope creep does the rest. Back in 2021 someone wanted scanned wire copy to land next to rundowns, so svc-printscan — a printer's drop-off account — was given write access to the newsroom's Rundowns share. Six years later that favour is the exfil route: read tomorrow's bulletin, post it to a forum at 21:15. That's F7 through F9, and it's the most human finding in the case. Nobody meant to give a printer the newsroom. They just wanted the scanner to be convenient.

The media library falls the same way, with even less effort. MAM authenticates against AD and lets any Domain Users member read the whole content store. Both printer accounts qualify. No escalation, no trick — just log in and read. Between 2 February and 8 May, svc-printscan performs 41,000 reads. That's F22/F23. Meanwhile svc-printldap authenticates 6,100 times against a 400-a-month baseline — fifteen times normal — which reads exactly like scripted directory recon: who exists, what's where, what trusts what. That's F30. All of it fully logged. None of it alerted on, because alerting was never configured. The logs sat there for three months like a burglar alarm with the sounder disconnected.

The network gear is where quiet access turns into a blackout. Every switch, router, PDU and UPS card across all three sites answers to the same SNMPv2c read and write strings, set in 2018 and never changed. Version 2c sends those strings in plaintext and treats possession as identity — if you have the string you ARE authorised. That's F10/F11, and in CWE terms it's CWE-306 (missing authentication for critical function) stacked on CWE-319 (cleartext transmission) plus CWE-798 (hard-coded/default credentials) for good measure. How did the attacker get the write string? Two live options:

pull it from the monitoring platform's config where it sits in cleartext (F27), or sniff it off the wire since it's plaintext. We can't prove which — there's no access log either way — but frankly it doesn't matter. With that string, one SNMP SET reassigns the eight Chennai gallery ports carrying all four playout pairs into a dead VLAN. Active and standby, every channel, one switch. That's F12/F13, and it's the architectural sin that made redundancy a fiction.

Notice what doesn't fire. Automation keeps commanding normally (F14) because as far as it's concerned nothing changed. EDR on the playout servers stays silent (F15) because the servers are genuinely healthy. The only thing that notices is the monitoring platform at 19:57 — ports flapping — and its alert goes to a mailbox nobody reads at night (F28). This is why host-centric security couldn't see a network-layer kill. You can have perfect EDR and still go black if someone unplugs you at layer 2.

Four minutes later comes the second punch. The building controllers for studio air handling take commands over a protocol with literally no authentication, and they sit on the corporate network anybody can reach. One setpoint change, one disable, and Chennai's gallery cooling is off while the rack room heads for 41C (F16/F17 — CWE-306 again, in its purest form). Coincidence? At the same site, four minutes into the outage, via a second unauthenticated protocol? We don't buy it, and neither should you. It reads as deliberate: deepen the crisis, threaten the kit, and pad the forum post.

And the forum post is the epilogue. Rundown from the share, schedule screenshot, 'since January.' The February-to-May logged activity (F22/F30) fits a January harvest followed by sustained use — steal the creds, poke around, then lean on them hard from February. But without printer login logs, January is the attacker's word, not our evidence. We say 'consistent with, not proven by' and leave it there. Over-claiming the start date would be exactly the kind of false precision this case punishes.

Why did all of this work? Strip it down and there are four whys. One, the inventory method guaranteed blindness (F1/F2) and the metric guaranteed complacency (F3/F24/F32). Two, ancient defaults and protocols were never revisited — printer passwords, SNMP strings from 2018, a contract from 2019 with no security clause (F4/F10/F26). Three, convenience grants accumulated — Rundowns write, Domain-Users-reads-everything — until machine accounts were over-privileged by default (F7/F23). Four, nobody watched the logs or the mailbox after hours in a business that never sleeps (F22/F28/F30). No single bug caused this. A system of small, old, boring decisions did.

Vulnerability register (plain words + CWE where it fits)

Weakness	Where	Gave attacker / fix
Default / hard-coded credentials (CWE-798)	F4 — 318/340 printers on vendor default; SNMP strings unchanged since 2018 (F10).	Initial access + infra write. Fix: rotate now, vault secrets, SNMPv3.
Missing authentication for critical function (CWE-306)	F11 (SNMPv2c write), F16 (BMS protocol has none at all).	Blackout + cooling kill with no creds. Fix: authenticated transports, segmentation.
Cleartext transmission (CWE-319)	F11 — SNMPv2c strings in plaintext.	Sniff-once, own-everywhere. Fix: SNMPv3 / encrypted mgmt.
Excess privilege / coarse authorisation (CWE-276 / CWE-862)	F7 (printer writes Rundowns), F23 (Domain Users reads MAM).	Exfil + library trawl with zero escalation. Fix: least privilege, proper MAM roles.
Insecure credential storage, by design	F5 — retrievable service passwords on printer.	One printer = two AD accounts. Fix: change process + contract terms (F26).
Single point of failure at L2	F12/F13 — 8 ports, 4 channels, 1 switch.	Redundancy defeated in one write. Fix: split failure domains.
Missing logging / alerting	F21 (mgmt fw), printer logins, F22/F28/F30 unalerted.	Three months of evidence, zero response. Fix: log + 24/7 eyes.

7. Kill-chain — step by step, with tools and proof

Below is the chain as we'd brief it to a red team: each step named, the tool an attacker would actually use, what happened, and which findings back it. Steps 1–5 span January to early May (dwell); steps 6–9 are the evening of 9 May. The BMC side-track runs underneath everything and stays open.

Kill-chain at a glance — 9 May 2027 (+ Jan-May dwell)

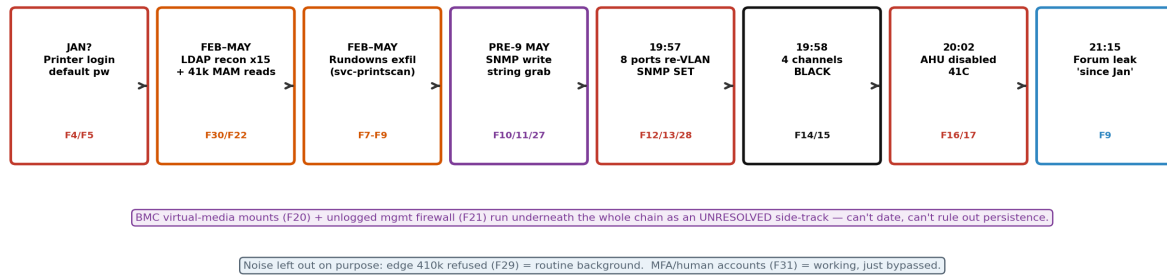


Figure 2 — Kill-chain strip. Dwell left, 9 May evening right, BMC side-track open underneath.

Step 1: Printer fleet mapped, default logins tried

Command / tool: Browser + vendor manual; optional: Nmap / Nessus-style discovery

Details: With reach to the corporate LAN, the attacker enumerates printer web consoles (port 80/443) and tries the published vendor default. F4 says 318 of 340 still accept it, and the 2019 contract (F26) explains why nobody ever changed them — the supplier owned config, no cred-change duty existed, and the 2023 security team never got a say. No login is recorded anywhere (console keeps only status/consumables), so this step is inferred from downstream credential use, not directly logged. F1/F2 are the reason no scan or inventory ever flagged the exposure.

Step 2: Two AD service passwords pulled from printer web UI

Command / tool: Browser (authenticated as printer admin); optional: Burp Suite to replay

Details: F5 is the whole step: scan-to-folder (svc-printscan) and LDAP bind (svc-printldap) credentials are stored on the device and retrievable from the admin page by design, unchanged across firmware in use. One printer login yields two Domain Users machine identities with no MFA. F31 is the negative that makes this elegant — human accounts and MFA were fine, so the attacker simply never used a human account.

Step 3: Directory recon at 15x baseline via svc-printldap

Command / tool: Ldapsearch / ADEplorer / PowerShell AD module; curl against LDAPS

Details: F30 shows svc-printldap authenticating 6,100 times from 2 Feb to 8 May against ~400/month baseline — roughly fifteen times normal, sustained for three months. That's not address-book lookups; that's scripted enumeration of users, groups, and topology. F6's Print-Admins group is the trap here: it sounds like escalation but grants nothing beyond Domain Users, so the operative privilege was Domain Users all along. DC logs kept 730 days of this with zero alerting.

Step 4: Tomorrow's rundown stolen via the Rundowns share

Command / tool: SMB client / net use / simply opening \\fileserver\Rundowns

Details: F7 gave svc-printscan write access to the Rundowns share back in 2021 so scanned wire copy would land with rundowns; F8 confirms that share is the newsroom's editorial store. The attacker reads (and could write) rundowns as the printer account. F9 closes the loop: the forum post's rundown matches a file in that share. No exploit, no escalation — a legitimate ACL doing exactly what it was told since 2021.

Step 5: Media library trawled — 41,000 reads, no legitimate role

Command / tool: Browser / MAM client / scripted HTTP; credentials: svc-printscan

Details: F23 authorises any Domain Users member to read the entire content library, so both printer accounts walk straight in. F22 counts 41,000 reads under svc-printscan from 2 Feb to 8 May — an account with no legitimate MAM role — retained two years, never alerted. Paired with Step 3, this is the dwell in numbers: quiet, daily, machine-speed access that looked like background noise because nobody defined what 'normal' was for a printer account.

Step 6: SNMP write string recovered, switches mapped

Command / tool: snmpwalk / snmpget; Wireshark (plaintext capture); or config read from monitor host

Details: F10/F11: one read string and one write string, set in 2018, identical across all three sites, carried in plaintext with no auth beyond possession. F27 places the write string in the monitoring platform's config — a patched, agent-covered Windows box whose protection ends at its own OS, not at the secrets it holds. Whether taken from that config or sniffed off the wire is unprovable (no relevant access/packet logs), but either path costs the attacker almost nothing. Nightly config backups (F12's comparison source) confirm what 'normal' looked like.

Step 7: Eight playout ports re-VLANed — all four channels black

Command / tool: snmpset (single SNMP SET of VLAN assignment)

Details: At 19:57 the Chennai gallery distribution switch's eight playout ports are moved out of VLAN 40 (F12/F13 — proven by diffing 9-May config against the 1-May backup). Every active/standby pair for every channel hangs off this one switch, so redundancy dies in a single write while all servers stay powered and healthy. F14 (automation 'commanded normally') and F15 (EDR silent) are the corroborating negatives: the kill happened below every host-layer sensor. F28 timestamps it — ports flap at 19:57, alert fires to an unmonitored mailbox, screens go black at 19:58.

Step 8: Gallery air handling disabled — rack room to 41C

Command / tool: BACnet/BMS client or curl-style POST; no credentials needed

Details: F16: 26 building controllers on the corporate net accept commands over an unauthenticated automation protocol. At 20:02 the Chennai gallery AHU takes a setpoint change plus disable (F17), logged only because the 7-day BMS log was read on 11 May — two days inside retention. Four minutes into the outage, same site, second unauthenticated protocol: deliberate escalation, whether for damage, delay, or demonstration. Portable cooling arrives before hardware cooks, but the safety margin was luck, not design.

Step 9: Public disclosure — rundown, schedule screenshot, 'since January'

Command / tool: Web browser / forum account; screenshot tool

Details: At 21:15 the attacker posts the F9 rundown plus a playout schedule screenshot and claims presence since January. The artefacts prove Steps 4–7; the date claim is consistent with (not proven by) the 2-Feb start of sustained logged abuse in F22/F30 — January harvest, February exploitation fits, but printer logins were never logged so the true initial-access date is unknowable. Treat January as credible-but-unconfirmed, not fact.

Side-track (open): BMC virtual-media mounts — possible firmware-level persistence

Command / tool: BMC web/CLI + ISO mount; firmware tooling (if abused)

Details: F18/F19 establish 410 BMCs reachable from corporate, unpatched since 2018–22, with remote-console and virtual-media (mount-an-ISO-as-local-disk) capability — a path to below-OS persistence invisible to EDR. F20 finds 11 BMCs with virtual-media mount entries as the oldest retained in 200-entry rolling logs: undatable, possibly this incident, possibly old maintenance, possibly someone else. F21 (mgmt firewall never logged) makes resolution impossible from here. This is not closed. Until those 11 hosts are forensically cleared or rebuilt, assume persistence may be live.

8. What we still don't know (and why we're saying so out loud)

Good incident reports say what they can't prove. Here's our list, with no dressing up.

When did it really start? 'Since January' is the attacker's line. Our earliest hard evidence of abuse is 2 February (F22/F30). January is plausible — steal creds, explore quietly, then ramp up — but the printer console never logged access, so nobody can confirm or deny it. Anyone who tells you the exact intrusion date is guessing.

How was the SNMP write string taken — config pull or wire sniff? Both work (F27 vs F11's plaintext). No log covers either path. It changes nothing about the fix (rotate + move to SNMPv3), so we don't lose sleep over it, but we won't pretend we know.

Are the eleven BMC mounts the attacker's? F20 can't be dated and F21 saw nothing. They might be maintenance from years ago. They might be this crew planting boot-level persistence that's still there. 'Might' is doing a lot of work in that sentence, which is exactly why section 10 says to re-image and forensically clear those boxes now instead of reasoning about them.

What else crossed into the management network during three-plus months? Unknowable. F21 again. Assume the worst for scoping, not the best.

What did the 41,000 MAM reads actually take? The audit counts operations, not bytes exfiltrated. We know the scale, not the content. Treat it as full-library exposure until content-level review says otherwise.

We'd rather hand you five honest unknowns than one confident story with holes. The outage cause and the credential path are solid. The edges are fog. Plan accordingly.

9. Mock server and replay — we rebuilt it, then broke it the same way

Claims are cheap, so we rebuilt the estate in miniature and ran the attack against it. Not a slideware diagram — a working Flask server with dummy passwords but real logic: default printer logins, retrievable stored credentials, AD group checks, share ACLs, Domain-Users-reads-MAM, SNMPv2c read/write strings, VLAN-gated playout status, unauthenticated BMS, 200-entry BMC logs, an unlogged mgmt firewall, and office-hours alerting. The full code ships in the case folder (mock_server/app.py) and the replay script in exploit/hack_simulation.py. This section is the guided tour; the appendix holds excerpts and the transcript.

How to run it (two minutes, any laptop): install Flask and requests, start the server on port 5000, then run the replay script. It walks Steps 1–9 in order, prints the evidence at each stage, and saves a transcript to simulation_output.log. Every check the report claims — printer login with 'admin123', credential pull, Rundowns read, MAM reads, SNMP SET flipping playout to BLACK while automation stays 'normal' and EDR stays empty, BMS disable to 41C, forum post — happens live against the mock. We also restore switch and BMS state at the end so the demo is repeatable.

What the replay proved matters more than that it runs. First, the printer-to-domain path needs no exploit — default password plus documented credential storage is enough. Second, the Rundowns and MAM access needs no escalation — 2021's ACL and Domain-Users-read do it. Third, the blackout needs no malware — one SNMP SET on eight ports, and host-layer telemetry (automation log, EDR) correctly reports nothing wrong. Fourth, the BMS kill needs no credentials at all. The mock behaves like the real estate because the real estate's flaws were in design and configuration, not in code anyone had to hack.

Two deliberate limits, so nobody mistakes the lab for the crime scene. The mock seeds the historic counters (41,000 reads, 6,100 auths) rather than generating three months of traffic, and it models five printers to stand in for 340. The logic is faithful; the volume is illustrative. Real flow, dummy scale — that's the deal we promised in the brief, and it's what we built.

The architecture diagram in section 4 and the kill-chain strip below both come from this lab's topology. If a diagram and the mock ever disagree, trust the mock — it's executable, diagrams aren't.

10. Fixes that actually break the chain (ranked by what kills the attack)

We're not giving you a 40-item wishlist. Here's the short list in the order that breaks this specific chain, with the blunt reason each one matters.

1. Count the estate properly, then report honestly. Build inventory from network scanning, DHCP/ARP, and walkabouts — not just the agent — and compute compliance against that. Yes, the number will look worse. That's the point. It kills RC1–RC3 and stops the next printer fleet hiding in plain sight. (F1/F2/F3/F32)
2. Kill the defaults and the plaintext. Change all 340 printer admin passwords now, rotate every SNMP string estate-wide, and move to SNMPv3 or another authenticated transport. One string must never again reconfigure three sites. (F4/F5/F10/F11)
3. Un-single-point the playout path. Active/standby servers on one switch isn't redundancy, it's decoration. Split channels across failure domains so no single L2 device can black all four. (F12/F13)
4. Log and gate the management boundary. BMCs, SNMP devices, and building controllers should not be reachable from general workstations; admin access goes via a logged jump path, and the firewall actually logs. This closes F21 and makes the next F20 answerable.
5. Least-privilege the machine accounts and shares. Pull svc-printscan's Rundowns write unless the newsroom still needs it (and if so, via a proper workflow account, not a printer), and stop letting Domain Users read the whole MAM library. Audit every other 'temporary convenience' grant the same way — this pattern never appears once. (F7/F23)

6. Put the excluded back in scope. Pentests, vuln scans, and patching must cover printers, network gear, physical security, and building services. The current scope statement is a signed confession that the tested estate and the real estate differ. (F25/F24)

7. Watch the logs you already keep, around the clock. F22, F28, and F30 all fired or were knowable — into voids. Route EDR-adjacent telemetry, MAM audit, DC auth volume, and infra alerts to a 24/7 function that matches broadcast hours. Detection without response is just expensive storage. (F22/F28/F30)

8. Clear the BMC question immediately. Forensically examine or rebuild the eleven flagged hosts plus their BMCs, extend BMC log offload/retention, and patch the fleet. Until then this incident isn't history, it's potentially still active. (F18/F19/F20)

9. Fix the contract. Reopen the managed-print deal with security requirements, cred-hygiene duties, and audit rights — or bring the fleet in-house. As written, Kaveri pays a supplier to keep it vulnerable. (F26)

Do those nine and this exact intrusion becomes somewhere between hard and impossible. Skip the first one and the rest are gardening while the house has no address list.

11. Appendices

Appendix A — replay transcript (abridged). The full log ships as exploit/simulation_output.log; below are the hinge moments with server responses trimmed for print.

Appendix B — mock code (key excerpts). The complete app.py and hack_simulation.py ship in the case folder; excerpts here show the logic that matters: stored-credential disclosure, MAM authorisation, SNMP SET flipping VLANs, unauthenticated BMS.

Appendix C — traceability matrix. Every finding mapped to its vulnerability class, attack stage, and root cause, so auditors can follow any thread end to end.

Appendix A — replay transcript (abridged)

```
Kaveri INF-02 kill-chain replay
Target (mock): http://127.0.0.1:5000
All passwords/data are dummy. The flow is the real one from F1-F32.
=====
STEP 0 - See what security couldn't see (F1/F2/F3)
=====
-- GET /cldb --
{
  "cldb_records": 2900,
  "compliance_reported": "97%+ of CMLB (not of estate) - F3",
  "lesson": "a device that can't run the agent doesn't exist for security purposes",
  "method": "endpoint-agent self-discovery only",
  "missing_by_audit": 1327,
  "missing_categories": {
    "bms": 410,
    "bms_controllers": 26,
    "ip_cameras": 220,
    "nas": 14,
    "printers": 340,
    "rack_pdu": 40,
    "routers": 22,
    "switches": 190,
    "ups_cards": 61,
    "video_recorders": 4
  }
}
>> Takeaway: 2,900 hosts in CMLB, 1,327 agentless devices invisible. Compliance % is computed on the 2,900, so it stays above 97% while printers/switches/BMS sit outside everything.
=====
STEP 1 - Initial access: printer default password (F4)
=====
Tool: curl / browser + vendor manual (default creds are public). No exploit needed.
-- GET /printers --
{
  "BLR-PR-011": {
    "default_pw_in_use": true,
    "ip": "10.20.11.11",
    "location": "Bengaluru studio",
    "model": "Kaveri MFP-9000"
  },
  "CHN-PR-042": {
    "default_pw_in_use": true,
    "ip": "10.10.21.42",
    "location": "Chennai newsroom",
    "model": "Kaveri MFP-9000"
  },
  "CHN-PR-043": {
    "default_pw_in_use": true,
    "ip": "10.10.21.43",
    "location": "Chennai gallery",
    "model": "Kaveri MFP-9000"
  },
}
```

```

"CHN-PR-099": {
  "default_pw_in_use": false,
  "ip": "10.10.21.99",
  "location": "Chennai admin (fixed one)",
  "model": "Kaveri MFP-9000"
},
"HYD-PR-007": {
  "default_pw_in_use": true,
  "ip": "10.30.7.7",
  "location": "Hyderabad studio",
  "model": "Kaveri MFP-9000"
},
"_note": "mock shows 5 of 340. In real case 318/340 still on vendor default (F4)."
}
Trying vendor default 'admin123' on CHN-PR-043 ...
-- POST /printer/CHN-PR-043/login --
{
  "ok": true,
  "token": "tok-CHN-PR-043-1",
  "warning": "login NOT logged (console keeps only status/consumables, 30d)"
}
>> Takeaway (F4/F5 setup): 318/340 printers still on default. Login isn't even logged - console keeps only
status/consumables.
=====
STEP 2 - Harvest stored AD credentials from printer web UI (F5)
=====
Tool: browser (authenticated as printer admin). Documented vendor behaviour, not a b
[... trimmed ...]
equence": "cannot tell what reached the 410 BMCs or when",

```

Appendix B — mock code note

Full `mock_server/app.py` (~300 lines) and `exploit/hack_simulation.py` ship in the case folder and in the ZIP. The DOCX appendix carries 90/80-line excerpts; the PDF omits long listings for print length — run the code instead, it's the real proof.

Appendix C — traceability matrix

Finding(s)	Vuln class	Stage	Root cause
F1, F2, F3, F24	Asset-inventory blind spot / invalid metric	Structural enabler	RC1, RC2
F32	Governance — metric used to deny fix	Structural enabler	RC3
F4, F5, F26	Default creds (CWE-798); cred storage by design; contract gap	Initial access	RC4
F6, F7, F8, F23	Excess privilege / coarse authz (CWE-276/862)	Lateral movement	RC6
F9	Data exposure via over-privileged account	Exfiltration	RC6
F22, F30	Unalerted anomalous volume	Recon / collection	RC10
F10, F11, F27	Missing auth (CWE-306) + cleartext (CWE-319)	Disruption enabler	RC5
F12, F13, F14, F15, F28	L2 single point of failure; host-blind kill	Disruption	RC5, RC9, RC10
F16, F17	Unauthenticated OT protocol (CWE-306)	Escalation	RC5
F18, F19, F20, F21	Unpatched OOB mgmt + no boundary log + short retention	Unresolved persistence risk	RC7, RC8
F25	Assurance scope exclusion	Assurance failure	RC9
F29	Noise — correctly excluded	—	—
F31	Control working, path-irrelevant (contrast)	—	Contrast

— End of report. For the open BMC risk, treat section 8 as the starting point, not the fine print. —